

**INSTITUTO FEDERAL DE EDUCAÇÃO, CIÊNCIA E TECNOLOGIA DE SÃO PAULO
CAMPUS SÃO PAULO**

TECNOLOGIA EM ANÁLISE E DESENVOLVIMENTO DE SISTEMAS

**JOAO ANTÔNIO CHAMUSCA MARTINS
KELVYN GABRIEL MILU DE OLIVEIRA
LUCAS VIEIRA DE SOUZA
MATHEUS PEREIRA PEREIRA**

**SISTEMA INTELIGENTE DE MONITORAMENTO E SEGURANÇA
CIBERNÉTICA: APOIO À PROTEÇÃO E ORIENTAÇÃO SOBRE A
VULNERABILIDADE DIGITAL (SafeID)**

SÃO PAULO

2026

JOAO ANTÔNIO CHAMUSCA MARTINS
KELVYN GABRIEL MILU DE OLIVEIRA
LUCAS VIEIRA DE SOUZA
MATHEUS PEREIRA PEREIRA

SISTEMA INTELIGENTE DE MONITORAMENTO E SEGURANÇA
CIBERNÉTICA: APOIO À PROTEÇÃO E ORIENTAÇÃO SOBRE A
VULNERABILIDADE DIGITAL (SafeID)

Projeto apresentado ao Programa do Curso de Tecnologia em Análise e Desenvolvimento de Sistemas, do Instituto Federal de Educação, Ciência e Tecnologia de São Paulo, Campus de São Paulo, como requisito parcial para aprovação na disciplina SPOPIE1 – Projeto Integrado de Extensão 1, sob orientação do Professor Anderson Gomes Peixoto.

SÃO PAULO

2026

RESUMO

A crescente dependência de serviços digitais por indivíduos e organizações tem gerado um rastro massivo de informações pessoais e de acesso restrito, tornando-as vulneráveis a incidentes de segurança. No cenário atual, a exfiltração de dados em larga escala e a subsequente compilação de bases de credenciais expostas em repositórios de *threat intelligence* representam um risco crítico à privacidade e à integridade dos titulares. Diante dessa realidade, este trabalho apresenta o SafeID, um sistema desenvolvido para permitir ao usuário (cadastrado ou não) monitorar exposições registradas e oferecer apoio e orientação sobre sua vulnerabilidade digital.

O objetivo central do projeto é consolidar uma plataforma que atue no processamento e na triagem de informações provenientes de fontes externas que catalogam esses incidentes de segurança. Ao contrário de ferramentas de detecção em tempo real, o SafeID foca no mapeamento de dados que já foram comprometidos e estão circulando em repositórios de ameaças conhecidos. O sistema busca democratizar o acesso a essa informação técnica sobre o contexto da vulnerabilidade digital, permitindo que o cidadão comum compreenda se seus dados cadastrais ou credenciais de acesso fazem parte de vazamentos documentados, facilitando a gestão de sua própria identidade digital.

Metodologicamente, a pesquisa utiliza uma abordagem de desenvolvimento ágil para a criação de uma aplicação fundamentada em React e Node.js. O diferencial do sistema reside na aplicação de modelos de inteligência artificial (LLMs) para realizar uma análise cognitiva dos incidentes encontrados, transformando registros técnicos em guias práticos de mitigação. Assim como, o SafeID propõe como entrega de valor um índice de risco visual — o "score de exposição" — e planos de ação personalizados. Dessa forma, a plataforma cumpre as diretrizes da Lei Geral de Proteção de Dados (LGPD) ao fortalecer a autodeterminação informativa e a cultura de segurança preventiva no Brasil.

Palavras-chaves: Segurança cibernética. Inteligência de Ameaças. LGPD. Inteligência Artificial.

ABSTRACT

The growing reliance on digital services by individuals and organizations has generated a massive trail of personal and restricted access information, making them vulnerable to security incidents. In the current scenario, large-scale data exfiltration and the subsequent compilation of exposed credential databases in threat intelligence repositories represent a critical risk to the privacy and integrity of data subjects. Given this reality, this paper presents SafeID, a system developed to allow users (registered or not) to monitor recorded exposures and offer support and guidance on their digital vulnerability.

The central objective of the project is to consolidate a platform that operates in the processing and screening of information from external sources that catalog these security incidents. Unlike real-time detection tools, SafeID focuses on mapping data that has already been compromised and is circulating in known threat repositories. The system seeks to democratize access to this technical information regarding the context of digital vulnerability, allowing ordinary citizens to understand if their registration data or access credentials are part of documented leaks, facilitating the management of their own digital identity.

Methodologically, the research uses an agile development approach to create an application based on React and Node.js. The system's differential lies in the application of artificial intelligence models (LLMs) to perform a cognitive analysis of the incidents found, transforming technical records into practical mitigation guides. Furthermore, SafeID proposes as a value delivery a visual risk index — the "exposure score" — and personalized action plans. In this way, the platform complies with the guidelines of the General Data Protection Law (LGPD) by strengthening informative self-determination and the culture of preventive security in Brazil.

Keywords: Cybersecurity. Threat Intelligence. LGPD. Artificial Intelligence. SafeID.

ÍNDICE DE FIGURAS

- Figura 1 – Arte principal do SolidariData **Erro! Indicador não definido.**
- Figura 2 - Logotipo do SolidariData **Erro! Indicador não definido.**
- Figura 3 - Diagrama UML do SolidariData **Erro! Indicador não definido.**
- Figura 4 - Ilustração do caso de uso do usuário do SolidariData**Erro! Indicador não definido.**
- Figura 5 - Diagrama de atividade de cadastramento no SolidariData**Erro! Indicador não definido.**
- Figura 6 - Modelo Conceitual do Banco de Dados do SolidariData**Erro! Indicador não definido.**
- Figura 7 - Modelo Lógico do Banco de Dados do Solidaridata **Erro! Indicador não definido.**

ÍNDICE DE TABELAS

Tabela 1 - Cronograma de Atividades	Erro! Indicador não definido.
---	--------------------------------------

ÍNDICE DE ABREVIACÕES E SIGLAS

IFSP	Instituto Federal de Educação, Ciência e Tecnologia de São Paulo
SBDG	Sistema de Gerenciamento de Banco de Dados
ONG	Organização Não Governamental
API	Application Programming Interface
JSON	JavaScript Object Notation
UML	Unified Modeling Language
CPF	Cadastro de Pessoas Físicas
CNPJ	Cadastro Nacional da Pessoa Jurídica
CRUD	Create, Read, Update, Delete
ACID	Atomicidade, Consistência, Isolamento e Durabilidade
UDF	User Defined Functions

SUMÁRIO

1. INTRODUÇÃO.....	9
1.1 Objetivos.....	11
1.1.1 Objetivo Geral	11
1.1.2 Objetivo Específico	11
1.2. Problema e Solução Proposta	11
1.2.1 Problema.....	11
1.2.2 Solução Proposta.	12
1.3 Justificativa.....	12
1.4 Análise da Concorrência.....	13
1.4.1 Have I Been Pwned (HIBP).....	13
1.4.2 Mozilla Monitor.....	13
1.4.3 Soluções de Identidade (Ex: LifeLock, Aura)	13
1.5 Quadro Comparativo de Funcionalidades	14
1.6 Layout, Arquitetura e Interface	14
3.2 Banco de Dados	Erro! Indicador não definido.
3.3 Front-End.....	Erro! Indicador não definido.
4. CRONOGRAMA DE ATIVIDADES.....	Erro! Indicador não definido.
5. DEFINIÇÕES DE REQUISITOS	Erro! Indicador não definido.
5.1 Requisitos Funcionais.....	Erro! Indicador não definido.
5.1 Requisitos não funcionais.....	Erro! Indicador não definido.
6. PROJETO DE SOFTWARE	Erro! Indicador não definido.
6.1 ..~.....	Erro! Indicador não definido.
6.2 Casos de Uso	Erro! Indicador não definido.
7. MODELAGEM/PROJETO DO BANCO DE DADOS	Erro! Indicador não definido.
7.1 Projeto do Banco de Dados	Erro! Indicador não definido.
7.3 Projeto Lógico	Erro! Indicador não definido.
8. CONSIDERAÇÕES FINAIS	Erro! Indicador não definido.
REFERÊNCIAS BIBLIOGRÁFICAS	37

1. INTRODUÇÃO

A transformação digital observada nas últimas décadas tem promovido mudanças significativas na forma como indivíduos, organizações e governos produzem, armazenam e compartilham informações. Com a ampliação do acesso à internet e a intensificação do uso de serviços digitais, dados pessoais passaram a ser constantemente coletados e processados em diferentes plataformas, tornando-se ativos de grande valor econômico e estratégico. Nesse cenário, a segurança da informação assume papel fundamental, especialmente no que se refere à proteção da privacidade e à integridade dos dados dos usuários (VON SOLMS et al., 2013)

Paralelamente a esse avanço tecnológico, observa-se o crescimento expressivo de incidentes relacionados ao vazamento de dados. Esses eventos, caracterizados pela exposição indevida de informações sensíveis, têm se tornado cada vez mais frequentes e complexos, afetando milhões de usuários em escala global. Segundo estudos recentes, a exploração de vulnerabilidades em sistemas, aliada a práticas inadequadas de gestão da informação, contribui significativamente para o aumento desses incidentes (ZHANG et al., 2022). Além disso, a sofisticação das ameaças cibernéticas, como ataques de engenharia social e campanhas automatizadas de coleta de credenciais, intensifica o cenário de risco.

No contexto brasileiro, a problemática da exposição de dados pessoais apresenta características particulares. O aumento do uso de plataformas digitais, impulsionado por fatores como inclusão digital e expansão de serviços online, tem ampliado a quantidade de informações sensíveis disponíveis na rede. Entretanto, esse crescimento não foi acompanhado, na mesma proporção, por uma cultura consolidada de segurança digital entre os usuários. Pesquisas apontam que práticas como reutilização de senhas, ausência de autenticação em múltiplos fatores e desconhecimento sobre vazamentos são recorrentes, tornando os indivíduos mais vulneráveis a fraudes e ataques (NEMEC ZLATOLAS et al., 2024).

Outro aspecto relevante refere-se às consequências desses vazamentos. Para além da exposição de dados, tais incidentes podem resultar em prejuízos financeiros, danos à reputação e comprometimento da privacidade dos indivíduos. No Brasil, estudos recentes indicam que o impacto econômico associado a violações de dados tem apresentado crescimento contínuo, refletindo não apenas falhas técnicas, mas também lacunas em políticas de proteção e conscientização dos usuários (CHEN; HENRY; JIANG, 2023). Dessa forma, o problema ultrapassa a dimensão tecnológica, configurando-se também como uma questão social e educacional.

Apesar da existência de ferramentas voltadas à identificação de vazamentos de dados, observa-se que grande parte dessas soluções apresenta limitações relevantes. Em geral, tais

sistemas fornecem informações de forma técnica, sem considerar o nível de compreensão do usuário comum. Como consequência, mesmo quando o indivíduo tem acesso à informação sobre a exposição de seus dados, ele pode não ser capaz de interpretar corretamente o risco ou adotar medidas adequadas de mitigação. Nesse sentido, a literatura destaca a importância de abordagens que integrem aspectos tecnológicos e educacionais, facilitando a compreensão e promovendo o uso seguro de sistemas digitais (CHEN; WANG, 2024).

Diante desse cenário, torna-se evidente a necessidade de soluções que não apenas identifiquem a exposição de dados, mas também auxiliem o usuário na interpretação das informações e na tomada de decisões. O uso de tecnologias baseadas em inteligência artificial apresenta-se como uma alternativa promissora nesse contexto, uma vez que permite a análise de grandes volumes de dados e a geração de respostas adaptadas ao perfil do usuário. Estudos recentes indicam que sistemas inteligentes podem contribuir significativamente para a comunicação de riscos de forma mais acessível e personalizada (REUBEN-OWOH, 2025).

Com base nessas premissas, o presente trabalho propõe o desenvolvimento do **SafeID**, uma plataforma web voltada ao monitoramento da exposição digital de usuários comuns. A solução integra mecanismos de verificação de vazamentos por meio de APIs especializadas em monitoramento de incidentes e inteligência de ameaças, um modelo de cálculo de risco baseado em regras e um assistente inteligente capaz de interpretar os resultados e fornecer orientações em linguagem acessível. Diferentemente das abordagens tradicionais, o SafeID busca atuar não apenas como uma ferramenta de diagnóstico, mas também como um instrumento de conscientização e apoio à tomada de decisão.

A proposta fundamenta-se na ideia de que a proteção de dados pessoais deve ser acessível a todos os usuários, independentemente de seu nível de conhecimento técnico. Ao traduzir informações complexas em recomendações claras e práticas, o sistema contribui para a redução de riscos associados a fraudes, invasões de contas e outras ameaças digitais. Dessa forma, o SafeID alinha-se às demandas contemporâneas por soluções que conciliem tecnologia, usabilidade e educação digital.

Por fim, destaca-se que a relevância deste estudo está diretamente relacionada à crescente dependência de sistemas digitais e à necessidade de fortalecimento da cultura de segurança da informação. Ao propor uma abordagem centrada no usuário e apoiada por tecnologias emergentes, este trabalho busca contribuir para o desenvolvimento de soluções mais eficazes no enfrentamento dos desafios relacionados à exposição de dados na sociedade digital.

1.1 Objetivos

1.1.1 Objetivo Geral

Desenvolver a plataforma **SafeID**, um sistema inteligente de apoio à decisão focado em segurança cibernética preventiva, capaz de processar informações provenientes de repositórios de *threat intelligence* focados em incidentes de exposição de dados para diagnosticar a exposição de dados pessoais e fornecer diretrizes de mitigação personalizadas por meio de inteligência artificial.

1.1.2 Objetivo Específico

- **Investigar, selecionar e consumir** APIs de monitoramento de exposições de incidentes de segurança *Open-Source Intelligence* (OSINT) que permitam a triagem automatizada de credenciais e dados cadastrais expostos;
- **Modelar e implementar** um algoritmo de cálculo de *Risk Score* (índice de risco) que pondere a criticidade do vazamento com base na natureza dos dados comprometidos reportados pelas APIs;
- **Desenvolver** uma interface web responsiva que utilize elementos de visualização de dados (como o termômetro de risco) para facilitar a interpretação dos usuários;
- **Projetar uma arquitetura de persistência** que registre o histórico de consultas do usuário, armazenando os metadados dos incidentes em estruturas de dados flexíveis para acompanhamento evolutivo da segurança;
- **Integrar** um modelo de linguagem de grande escala (LLM) para atuar como assistente cognitivo, traduzindo metadados técnicos em planos de ação práticos e acessíveis;
- **Aplicar** os princípios de Privacy by Design e as diretrizes da Lei Geral de Proteção de Dados (LGPD), assegurando o tratamento ético e a proteção das informações coletadas durante o ciclo de uso do sistema.

1.2. Problema e Solução Proposta

1.2.1 Problema

A aceleração da transformação digital consolidou os dados pessoais como ativos de alto valor, porém, essa transição resultou em um rastro massivo de informações sensíveis vulneráveis. O cenário atual é marcado pela escala industrial dos incidentes: somente em 2023, o Brasil foi alvo de mais de **32,8 bilhões de tentativas de ataques cibernéticos**, consolidando-se como o segundo país mais atingido na América Latina (FORTINET, 2024). Somado a isso, o custo médio global de um vazamento de dados atingiu a marca histórica de **US\$ 4,45 milhões**,

representando um aumento de 15% em relação aos três anos anteriores (IBM SECURITY, 2023).

Apesar da magnitude desses indicadores, o titular dos dados enfrenta uma grave **assimetria de informação**. Enquanto grupos cibercriminosos compilam e comercializam bases de dados exfiltradas em repositórios de *threat intelligence* (onde bilhões de credenciais são disponibilizadas anualmente), o usuário comum raramente possui consciência da extensão de sua própria vulnerabilidade. Ferramentas de consulta existentes frequentemente entregam resultados em formatos técnicos brutos que não permitem uma interpretação imediata do risco (CONTI; DARGAHI; DEHGANTANHA, 2018). Essa lacuna gera inércia, pois o indivíduo, mesmo ciente do vazamento, não compreende a gravidade da exposição ou quais contramedidas devem ser priorizadas.

1.2.2 Solução Proposta.

Diante dessa lacuna, propõe-se o desenvolvimento do **SafeID**, uma plataforma inteligente de apoio à decisão que atua na camada de pós-incidente. A solução baseia-se no processamento de metadados provenientes de APIs especializadas em monitoramento de exposições (como *Have I Been Pwned*). O diferencial do SafeID reside na integração de três componentes centrais:

1. **Mapeamento Automatizado:** A triagem de incidentes vinculados ao identificador do usuário em repositórios de ameaças;
2. **Cálculo de Risk Score:** Um algoritmo ponderado que quantifica a gravidade da exposição com base na natureza do dado (ex: senhas possuem peso superior a nomes);
3. **Assistente Cognitivo:** O uso de modelos de linguagem (LLMs) para converter diagnósticos técnicos em planos de ação personalizados e compreensíveis.

Dessa forma, a plataforma transforma dados brutos de incidentes em literacia em segurança, permitindo que o usuário adote contramedidas eficazes para a proteção de sua identidade digital.

1.3 Justificativa

A relevância deste projeto fundamenta-se na necessidade de transpor as barreiras técnicas que impedem o cidadão comum de exercer sua **autodeterminação informativa**, direito assegurado pela Lei Geral de Proteção de Dados (LGPD). No Brasil, o crescimento exponencial de vazamentos não foi acompanhado por uma educação digital equivalente, tornando o fator humano o elo mais vulnerável na cadeia de segurança (NEMEC ZLATOLAS et al., 2024).

A justificativa para o desenvolvimento do SafeID sustenta-se em pilares estratégicos:

- **Mitigação de Riscos Sociais:** A ferramenta combate a vulnerabilidade cognitiva ao oferecer orientação clara em um cenário onde o desconhecimento sobre vazamentos é facilitador de fraudes financeiras e roubo de identidade.
- **Inovação Tecnológica:** O projeto explora a convergência de tecnologias emergentes, como a integração de APIs de segurança e o processamento de linguagem natural (NLP), para resolver um problema crítico de usabilidade e comunicação de risco cibernético (REUBEN-OWOH; HAIG, 2025).
- **Conformidade Legal:** Ao facilitar o diagnóstico de exposições históricas (CHEN; HENRY; JIANG, 2023), o sistema auxilia na redução de danos à reputação e prejuízos financeiros, fortalecendo a cultura de segurança preventiva no país.

1.4 Análise da Concorrência

O mercado de soluções voltadas à verificação de exposição de dados apresenta ferramentas consolidadas, variando de agregadores de incidentes a suítes completas de proteção de identidade. Contudo, a análise técnica revela que a maioria foca na **entrega do dado bruto**, negligenciando a camada de **interpretação e suporte à decisão** para o usuário leigo.

1.4.1 Have I Been Pwned (HIBP)

Referência global em agregação de incidentes, o HIBP destaca-se pela robustez de sua base de dados OSINT. No entanto, sua interface é estritamente técnica e informativa.

- **Limitação:** O sistema opera no modelo "consulta e resposta", sem fornecer uma métrica de gravidade (Score) ou um plano de mitigação que vá além de sugestões genéricas como a troca de senhas. É a fonte primária de dados do SafeID, mas não um assistente de segurança.

1.4.2 Mozilla Monitor

O serviço da Mozilla atua como uma camada de interface sobre os dados do HIBP, buscando humanizar a experiência do usuário.

- **Limitação:** Embora possua uma interface mais amigável e ofereça alertas por e-mail, as recomendações permanecem estáticas. Não há processamento de linguagem natural ou análise cognitiva dos vazamentos para gerar orientações específicas para diferentes perfis de incidentes.

1.4.3 Soluções de Identidade (Ex: LifeLock, Aura)

Plataformas comerciais de alto custo que oferecem monitoramento extensivo (incluindo *credit score* e vigilância em tempo real).

- **Limitação:** Além da barreira financeira, essas soluções apresentam alta complexidade de configuração e são frequentemente integradas a serviços bancários e de crédito, o

que as afasta do objetivo de uma ferramenta ágil e focada exclusivamente na **literacia em cibersegurança do cidadão comum**.

1.5 Quadro Comparativo de Funcionalidades

Abaixo, apresenta-se a comparação entre os concorrentes analisados e a proposta do SafeID, evidenciando o diferencial competitivo no uso de IA e Score de Risco.

Funcionalidade	HIBP	Mozilla Monitor	Soluções Pagas	SafeID
Consulta de incidentes (OSINT)	Sim	Sim	Sim	Sim
Alertas de novas exposições	Não*	Sim	Sim	Sim
Interface Acessível	Não	Sim	Parcial	Sim
Score de Risco Ponderado	Não	Não	Sim	Sim
Assistente Cognitivo (LLM)	Não	Não	Não	Sim
Foco em Educação Digital	Não	Parcial	Não	Sim

*A funcionalidade gratuita de consulta do HIBP não inclui alertas ativos para o usuário comum sem registro de domínio.

1.6 Layout, Arquitetura e Interface

Para que o SafeID se diferencie dos concorrentes, sua arquitetura foi projetada para ser leve e centrada no usuário, conforme o diagrama de blocos abaixo:

1. **Layout:** Utiliza o padrão *Mobile First* para garantir que o usuário possa consultar sua segurança em qualquer dispositivo.
2. **Arquitetura:** Baseada em microserviços para permitir que a integração com a LLM (Inteligência Artificial) não comprometa a performance da consulta às APIs de vazamento.
3. **Interface:** Foca na visualização de dados (gráficos para categorias de vazamento e um termômetro circular para o Score de Risco), eliminando o excesso de textos técnicos presentes nos concorrentes.

2 REVISÃO DA LITERATURA

2.1 A Economia da Informação e a Evolução das Ameaças Digitais

A transição para a economia digital reconfigurou o dado pessoal de um simples registro cadastral para um ativo estratégico de alto valor estratégico. De acordo com **Von Solms e Van Niekerk (2013)**, a cibersegurança evoluiu de uma disciplina estritamente técnica e

organizacional para uma dimensão de governança pessoal, onde a proteção da identidade digital do indivíduo torna-se o núcleo da defesa em rede. Esta mudança de paradigma reflete a onipresença dos sistemas de informação na vida cotidiana, exigindo que a segurança acompanhe a mobilidade e a dispersão dos dados.

Contudo, essa valorização dos dados gerou o que a literatura define como "Economia da Exposição". Dados exfiltrados de grandes plataformas não são incidentes isolados, mas alimentam um mercado secundário de inteligência cibernética. **Conti, Dargahi e Dehghantanha (2018)** argumentam que a análise de ameaças baseada em evidências (*Threat Intelligence*) é a única forma de antecipar riscos em um ecossistema onde bilhões de credenciais já foram comprometidas e estão disponíveis para exploração.

O cenário brasileiro é um reflexo crítico dessa vulnerabilidade global. Relatórios recentes da **Fortinet (2024)** indicam que o Brasil sofreu mais de 32,8 bilhões de tentativas de ataques cibernéticos em um único ano, consolidando-se como o segundo país mais visado da América Latina. Esse volume massivo de tentativas de invasão justifica a necessidade de ferramentas que atuem no monitoramento constante de exposições, uma vez que a superfície de ataque expandiu-se proporcionalmente à digitalização dos serviços financeiros e sociais no país.

2.2 Custódia de Dados, Fadiga de Segurança e o "Gap" de Detecção

A robustez da segurança individual é frequentemente insuficiente devido às falhas na custódia de dados por grandes serviços digitais. Um indicador alarmante apresentado pela **IBM Security (2023)** revela que o ciclo de vida médio de um vazamento de dados, desde a sua ocorrência até a efetiva contenção, é de aproximadamente 277 dias. Este intervalo temporal é crítico, pois permite que informações sensíveis circulem livremente em repositórios de acesso restrito muito antes de o titular ser notificado ou adotar medidas de proteção.

Além do atraso na detecção, a literatura aponta para o fenômeno da "fadiga de segurança" como um agravante dos riscos. **Nemec Zlatolas et al. (2024)** discutem que a complexidade na gestão de múltiplas credenciais e a subutilização de métodos de Autenticação em Múltiplos Fatores (MFA) são consequências diretas da falta de ferramentas que traduzam o risco técnico para o usuário leigo. O problema reside na entrega de dados brutos sem o devido contexto, o que impede uma reação assertiva por parte do cidadão comum.

Dessa forma, a eficácia das contramedidas depende diretamente da capacidade de interpretação do usuário sobre o incidente. **Santos e Pinto (2025)** reforçam que a percepção de risco é distorcida por barreiras cognitivas e linguísticas, sugerindo que sistemas de segurança devem evoluir para interfaces de apoio à decisão. O SafeID busca preencher justamente esta

lacuna, transformando metadados de incidentes em orientações práticas, reduzindo o hiato de resposta entre a descoberta do vazamento e a ação mitigadora.

2.3 Marco Regulatório (LGPD) e a Literacia Digital no Brasil

A consolidação da Lei Geral de Proteção de Dados (LGPD - Lei 13.709/2018) estabeleceu no Brasil o direito fundamental à transparência e à autodeterminação informativa. No entanto, a aplicação prática desses preceitos esbarra na baixa literacia digital da população brasileira. Conforme analisado por **Chen, Henry e Jiang (2023)**, a simples divulgação de fatores de risco cibernético não é informativa o suficiente se não houver uma estrutura que permita ao titular dos dados compreender o impacto real daquela exposição em sua privacidade.

A necessidade de mediação tecnológica torna-se evidente quando observamos a disparidade entre o rigor normativo e a execução técnica. **Reuben-Owoh e Haig (2025)** destacam que a adoção de padrões voluntários de cibersegurança deve ser acompanhada por mecanismos que facilitem a comunicação de riscos de forma personalizada. No contexto brasileiro, onde a dependência de plataformas digitais é elevada, a proteção de dados deve ser encarada não apenas como conformidade jurídica, mas como um processo de educação e empoderamento do usuário.

Portanto, o SafeID integra-se a este cenário como um instrumento de apoio à conformidade e cidadania digital. Ao alinhar as diretrizes da LGPD com tecnologias de inteligência artificial, o sistema permite que o usuário exerça seu direito de monitoramento de forma autônoma. Conforme concluem **Chen e Wang (2024)**, a gestão social de incidentes cibernéticos exige abordagens que integrem a resposta técnica ao suporte educacional, promovendo uma cultura de segurança preventiva que transcenda o ambiente corporativo e alcance o cidadão comum.

3 GESTÃO DO PROJETO

3.1 Organização da Equipe

A equipe do SafeID é composta por quatro membros, distribuídos em funções que cobrem o ciclo completo de desenvolvimento, desde a concepção do produto até a implementação e persistência dos dados.

- **Matheus Pereira Pereira:** Product Owner e Scrum Master. Responsável pela visão do produto, gestão do *Backlog* e facilitação dos ritos ágeis.
- **Lucas Vieira de Souza:** Desenvolvedor Back-end. Responsável pela lógica de servidor, integração com APIs externas e inteligência artificial.

- **Joao Antônio Chamusca Martins:** Desenvolvedor Front-end. Responsável pela interface do usuário, responsividade e experiência do usuário (UX).
- **Kelvyn Gabriel Milu de Oliveira:** Desenvolvedor e Administrador de Banco de Dados (DBA). Responsável pela modelagem, integridade e performance das estruturas de dados.

3.1.1 Responsabilidades e Atividades

As atividades foram distribuídas de forma colaborativa, utilizando o modelo de matriz de responsabilidades. O PO/Scrum Master atua na interface com os requisitos de negócio, enquanto o time de desenvolvimento (DevTeam) foca na implementação técnica, garantindo que as integrações entre o Front-end, Back-end e Banco de Dados sejam coesas.

Integrante	Papel no Scrum	Especialidade Técnica	Atribuições e Entregas
Matheus Pereira	Scrum Master / PO	Gestão e Dados	Liderança da documentação acadêmica, gestão do <i>Backlog</i> , curadoria dos dados das APIs e validação do cálculo de risco (<i>Score</i>).
Kelvyn Gabriel	Desenvolvedor / DBA	Cibersegurança	Modelagem do banco de dados (MySQL/PostgreSQL), segurança da arquitetura, definição dos pesos de criticidade dos vazamentos e conformidade com a LGPD.
Lucas Vieira	Desenvolvedor	Back-end / APIs	Construção da API do SafeID (Node.js), integração com o <i>Have I Been Pwned</i> , conexão com a LLM (Inteligência Artificial) e lógica de processamento de metadados.
João Antônio	Desenvolvedor	Front-end / UX	Design da interface (Figma), desenvolvimento dos componentes em React, implementação do termômetro de risco e garantia da responsividade.

3.1.1.1 Sinergia entre Artefatos e Documentação

A gestão do projeto foi desenhada para que a construção conceitual e a técnica caminhem juntas:

- **Documentação Coletiva:** Embora o Matheus lidere a redação acadêmica, o Kelvyn e o Lucas e João são responsáveis por documentar as especificações técnicas (Dicionário de Dados, Diagrama de Classes e Documentação da API no GitHub).
- **Repositório Único (Monorepo):** Optamos por um repositório centralizado no GitHub. Isso facilita o rastreamento de quem desenvolveu cada *feature* e garante que a documentação técnica esteja sempre próxima ao código (*README.md* e *Wiki*).
- **Integração de Conhecimentos:** A experiência profissional do Kelvyn em cibersegurança alimenta diretamente a lógica do Lucas nas APIs, enquanto o Matheus traduz essa complexidade técnica para a linguagem acessível da documentação e da interface projetada pelo João.

3.2 Metodologias de Gestão e Desenvolvimento

O projeto adota o **Scrum** como metodologia ágil de gestão, permitindo entregas incrementais e adaptação rápida a mudanças de requisitos durante o processo de construção.

3.2.1 Scrum (Metodologia Ágil)

O Scrum foi selecionado por sua eficácia em projetos de tecnologia onde a integração de diferentes camadas (IA, APIs e Banco de Dados) exige ciclos constantes de inspeção e adaptação.

3.2.1.1 Sprints

As atividades foram organizadas em ciclos quinzenais (*Sprints*), iniciados em março de 2024.

- **Planejamento:** No início de cada Sprint, a equipe define os itens do *Backlog* a serem desenvolvidos.
- **Construção e Documentação:** Paralelamente ao código, a documentação técnica é atualizada para garantir o registro da arquitetura.
- **Reuniões de Alinhamento:** Realizadas para identificar impedimentos técnicos, especialmente na integração com as APIs de monitoramento de incidentes.

3.3 Repositório da Aplicação

A gestão de configuração e versão do código-fonte é realizada por meio de ferramentas de controle de versão distribuídas.

3.3.1 Definição do Repositório

Foi adotado o **Git** como sistema de controle de versão, utilizando o **GitHub** como plataforma de hospedagem. Esta escolha justifica-se pela facilidade de colaboração entre a equipe e a integração contínua (CI/CD) com ferramentas de deploy.

3.3.2 Link do Repositório e Especificações para Acesso

O projeto **SafeID** adota o modelo de **Monorepo**, centralizando toda a inteligência de dados, documentação e código-fonte em um único repositório gerenciado dentro de uma organização no GitHub. Essa estrutura garante a rastreabilidade das entregas e a integridade entre o desenvolvimento técnico e a documentação acadêmica.

Organização dos Diretórios:

- **/client**: Contém o código-fonte da interface web desenvolvida em **React.js**.
- **/server**: Contém a lógica de negócio, integração com APIs OSINT e o motor de IA em **Node.js**.
- **/database**: Scripts de migração (DDL/DML), modelagem Entidade-Relacionamento e exemplos de esquemas de dados.
- **/docs**: Documentação oficial do projeto (incluindo o arquivo Word e versões em PDF), além de registros de requisitos.
- **/assets**: Diagramas de arquitetura, logotipos e recursos visuais do sistema.

Link de Acesso: <https://github.com/Safe-ID/safeid-main>

O repositório está configurado com um arquivo **README.md** na raiz que orienta a navegação e o processo de instalação. As entregas de cada sprint são evidenciadas através do histórico de *commits* e *logs* de atividades dos membros, permitindo a auditoria das contribuições individuais mencionadas no cronograma e validando a evolução do Produto Mínimo Viável (MVP).

3.3.3 Backlog do Produto (Product Backlog)

Seguindo as boas práticas no desenvolvimento de sistemas com a metodologia empregada, o Backlog do SafeID foi categorizado para permitir uma visão clara do que compõe o Protótipo (PI-1) e a Versão Final (PI-2).

ID	Categoria	Descrição do Item	Fase	Prioridade
01	Requisito	Levantamento de requisitos funcionais e não funcionais.	PI-1	Essencial

02	Requisito	Pesquisa e seleção de APIs de monitoramento (OSINT).	PI-1	Essencial
03	Arquitetura	Definição da stack tecnológica (React, Node.js, DB).	PI-1	Essencial
04	Banco de Dados	Modelagem do Diagrama Entidade-Relacionamento (DER).	PI-1	Essencial
05	Banco de Dados	Implementação do esquema de tabelas para histórico e usuários.	PI-1	Alta
06	Front-end	Prototipação de alta fidelidade (Figma).	PI-1	Alta
07	Back-end	Desenvolvimento do servidor API (Node.js).	PI-1	Essencial
08	Integração	Implementação do módulo de consumo da API externa (HIBP).	PI-1	Essencial
09	Lógica	Desenvolvimento do algoritmo de cálculo de <i>Risk Score</i> .	PI-1	Essencial
10	Front-end	Implementação da tela de consulta por identificador (E-mail).	PI-1	Alta
11	Front-end	Desenvolvimento do Dashboard de visualização de vazamentos.	PI-1	Alta
12	Documentação	Redação dos Capítulos 3 e 4 (Gestão e Análise).	PI-1	Essencial
13	Segurança	Implementação de autenticação e autorização (JWT/Login).	PI-2	Alta
14	Inteligência	Integração com LLM para interpretação de dados técnicos.	PI-2	Alta
15	Inteligência	Geração automática de plano de ação preventivo (via IA).	PI-2	Alta
16	Back-end	Módulo de armazenamento de logs de consulta e auditoria.	PI-2	Média
17	Segurança	Criptografia de dados sensíveis em repouso (LGPD).	PI-2	Essencial
18	Front-end	Implementação de temas (Dark/Light mode) e acessibilidade.	PI-2	Baixa
19	Notificação	Sistema de envio de alertas automáticos via e-mail.	PI-2	Média

20	Qualidade	Realização de testes de integração e carga.	PI-2	Alta
21	Segurança	Testes de penetração (Pentest) e correção de vulnerabilidades.	PI-2	Essencial
22	Documentação	Finalização da monografia e revisão para banca final.	PI-2	Essencial

3.3.4 Detalhamento das Sprints (Projeto Integrado I - Março a Junho)

O cronograma de PI-1 foca na fundamentação teórica e na construção do protótipo funcional (MVP), cobrindo os itens **01 a 12** do Product Backlog.

Sprint 1: Concepção e Engenharia de Requisitos (Março)

- **Objetivo:** Estabelecer a base conceitual e técnica para o monitoramento de vazamentos.
- **Itens do Backlog:** 01, 02 e 12.
- **Artefatos:** Documento de Visão, Levantamento de Requisitos e Estudo de APIs (OSINT).
- **Entregas:** Definição do Escopo, Referencial Teórico e Configuração do Repositório.

Sprint 2: Modelagem e Design de Experiência (Abril)

- **Objetivo:** Traduzir os requisitos em arquitetura de dados e interface visual.
- **Itens do Backlog:** 03, 04, 05 e 06.
- **Artefatos:** DER (Diagrama Entidade-Relacionamento), Dicionário de Dados e Protótipo de Alta Fidelidade (Figma).
- **Entregas:** Arquitetura do Banco de Dados e Layout da Interface Homem-Máquina.

Sprint 3: Desenvolvimento do Core e Lógica de Risco (Maio)

- **Objetivo:** Implementar o motor de busca e o algoritmo de análise.
- **Itens do Backlog:** 07, 08 e 09.
- **Artefatos:** Servidor Node.js funcional, Módulo de integração HIBP e Algoritmo de cálculo de *Risk Score*.
- **Entregas:** Backend operacional capaz de processar e categorizar incidentes reais.

Sprint 4: Integração Front-end e Entrega do Protótipo (Junho)

- **Objetivo:** Consolidar a Prova de Conceito (PoC) para apresentação à banca.
- **Itens do Backlog:** 10, 11 e 12.
- **Artefatos:** Dashboard em React integrado ao Backend e Relatório Técnico Parcial.
- **Entregas:** Protótipo funcional com consulta e visualização de risco; Documentação de PI-1 finalizada.

3.3.5 Planejamento para Projeto Integrado II (Agosto a Dezembro)

Para o segundo semestre, o Roadmap foca na evolução do protótipo para um sistema robusto, implementando inteligência avançada e segurança rigorosa (Itens **13 a 22**).

Agosto e Setembro: Autenticação e Inteligência Cognitiva

- **Foco:** Garantir a privacidade do usuário e a camada de IA.
- **Itens do Backlog:** 13, 14, 15 e 16.
- **Atividades:** Implementação de autenticação JWT, integração com a API da LLM para interpretação dos vazamentos e geração do plano de ação preventivo personalizado.

Outubro: Conformidade, Segurança e Notificações

- **Foco:** Alinhamento com a LGPD e monitoramento ativo.
- **Itens do Backlog:** 17, 18 e 19.
- **Atividades:** Implementação de criptografia em repouso (banco de dados), desenvolvimento do sistema de alertas via e-mail e ajustes de acessibilidade e interface (Dark/Light mode).

Novembro: Garantia de Qualidade e Resiliência

- **Foco:** Estabilização do sistema para ambiente de produção.
- **Itens do Backlog:** 20 e 21.
- **Atividades:** Execução de testes de carga, testes de penetração (Pentest) para identificar vulnerabilidades e correções finais na lógica do sistema.

Dezembro: Encerramento e Defesa

- **Foco:** Consolidação dos resultados e apresentação final.
- **Item do Backlog:** 22.
- **Atividades:** Revisão ortográfica e técnica da monografia completa, preparação dos slides de defesa e entrega final do sistema SafeID funcional à banca examinadora.

4 DESENVOLVIMENTO DO PROJETO

4.1 Escopo do projeto

O escopo do projeto **SafeID** compreende o desenvolvimento de uma aplicação web voltada à literacia e proteção de dados pessoais, atuando especificamente na camada de pós-incidente de segurança. A solução propõe-se a servir como uma ponte inteligível entre bases de dados técnicas de vazamentos (*data breaches*) e o usuário final, utilizando inteligência artificial para personalizar orientações de mitigação.

O que será desenvolvido (Inclusões):

- **Módulo de Consulta:** Interface para que o usuário submeta identificadores (como e-mail) para verificação em bases de dados OSINT (Open Source Intelligence), utilizando integração via API com provedores consolidados no mercado de cibersegurança.
- **Motor de Análise de Risco:** Algoritmo que processa a natureza do vazamento (ex: exposição de senhas, endereços IP, nomes completos) e atribui uma métrica de gravidade ponderada (*Risk Score*).
- **Assistente de Orientação (IA):** Integração com modelos de linguagem de larga escala (LLM) para traduzir metadados técnicos em planos de ação preventivos e compreensíveis para o público leigo.
- **Painel de Controle (Dashboard):** Visualização histórica das consultas realizadas e evolução do nível de exposição do usuário.

O que não será desenvolvido (Exclusões):

- **Recuperação de Contas:** O sistema não realizará ações diretas em contas de terceiros (ex: o SafeID não trocará a senha do e-mail do usuário automaticamente).
- **Monitoramento de Rede Local:** A aplicação não atuará como antivírus ou firewall residente no dispositivo do usuário.
- **Venda de Proteção Financeira:** O projeto não oferece seguros ou garantias financeiras contra fraudes, limitando-se à orientação e monitoramento informativo.

Premissas e Restrições da aplicação

- **Premissa:** O sistema depende da disponibilidade das APIs de terceiros (como *Have I Been Pwned*). Caso o serviço externo esteja offline, o SafeID apresentará uma mensagem de indisponibilidade momentânea, não sendo responsabilidade do grupo a manutenção de bases de dados de terceiros.
- **Restrição:** O sistema não realizará "quebra de hashes" ou descryptografia de senhas. Se o vazamento indicar que a senha está criptografada, o sistema apenas informará o status, cumprindo seu papel informativo e ético.

O projeto será entregue em duas etapas: no primeiro semestre, um **Protótipo Funcional (PoC)** validando a comunicação com APIs e a lógica de risco; no segundo semestre, a **Aplicação Integral** com interface finalizada, sistema de autenticação e o assistente cognitivo plenamente integrado.

4.1.1 Regras de negócio

As regras de negócio a seguir definem as restrições e o funcionamento lógico do SafeID, assegurando que o sistema opere em conformidade com as diretrizes de cibersegurança e proteção de dados.

- **RN01 – Identificador Único de Consulta:** O sistema deve aceitar como identificador primário para consulta o endereço de e-mail. Para a fase de PI-2, o sistema poderá ser expandido para outros identificadores, desde que validados por máscaras específicas.
- **RN02 – Ponderação do Score de Risco:** O cálculo do *Risk Score* deve ser baseado na criticidade dos dados expostos em cada vazamento. Dados como "Senhas" e "Dados Financeiros" possuem peso maior (ex: peso 10) do que "Nomes de Usuário" ou "Endereços IP" (ex: peso 2). O score final é a média ponderada de todas as ocorrências encontradas.
- **RN03 – Temporalidade do Risco:** Vazamentos ocorridos nos últimos 24 meses devem ter um impacto maior no score de risco do que vazamentos mais antigos, considerando que a probabilidade de a credencial ainda estar ativa é superior em incidentes recentes.
- **RN04 – Limitação de Consultas (Rate Limiting):** Para evitar abusos e garantir a estabilidade da integração com APIs externas, cada usuário (ou IP não autenticado no protótipo) terá um limite de 3 consultas por hora.
- **RN05 – Anonimização de Resultados Sensíveis:** O sistema nunca deverá exibir a senha vazada em texto claro. Caso o metadado do vazamento inclua a senha, o SafeID deve apenas informar a existência da exposição e orientar a troca imediata, preservando a segurança do usuário mesmo dentro da plataforma.
- **RN06 – Personalização via IA:** O plano de ação gerado pela Inteligência Artificial deve ser obrigatoriamente contextualizado ao tipo de vazamento encontrado. Se o vazamento for de "Dados de Cartão", a recomendação prioritária deve ser o bloqueio bancário; se for de "Senha", a troca de credenciais e ativação de MFA.
- **RN07 – Histórico de Privacidade:** Consultas realizadas por usuários não autenticados (visitantes) não serão armazenadas no banco de dados após o encerramento da sessão, visando o princípio de minimização da LGPD. Somente usuários cadastrados terão seus históricos preservados para fins de acompanhamento evolutivo.

4.1.2 Requisitos funcionais

Os requisitos funcionais descrevem as funções que o software deve executar para atender às necessidades dos usuários e as regras de negócio estabelecidas. Para o SafeID, os requisitos foram divididos entre o que será entregue no protótipo (PI-1) e a implementação final (PI-2).

ID	Requisito Funcional	Descrição	Fase
----	---------------------	-----------	------

RF01	Consulta por Identificador	O sistema deve permitir que o usuário insira um e-mail para verificar se há registros de exposição em bases de dados.	PI-1
RF02	Categorização de Incidentes	O sistema deve listar o nome das plataformas onde os dados foram vazados e quais tipos de dados foram expostos.	PI-1
RF03	Exibição do Risk Score	O sistema deve apresentar graficamente o índice de risco calculado pelo algoritmo de ponderação.	PI-1
RF04	Tratamento de Erros de Consulta	O sistema deve informar ao usuário caso o identificador inserido seja inválido ou não possua registros de vazamento.	PI-1
RF05	Geração de Relatório Resumido	O sistema deve gerar uma visualização simplificada (Dashboard) dos principais pontos de atenção do usuário.	PI-1
RF06	Integração Assistiva com IA	O sistema deve enviar os metadados do vazamento para a LLM e exibir uma explicação em linguagem natural para o usuário.	PI-2
RF07	Emissão de Plano de Ação	O sistema deve fornecer recomendações práticas (ex: trocar senha, ativar 2FA) baseadas na análise da IA.	PI-2
RF08	Criação de Conta de Usuário	O sistema deve permitir que o usuário se cadastre para salvar seu histórico e monitorar múltiplos identificadores.	PI-2
RF09	Monitoramento Ativo	O sistema deve realizar buscas periódicas automáticas para usuários cadastrados e alertar sobre novas exposições.	PI-2
RF10	Exportação de Plano de Mitigação	O sistema deve permitir que o usuário baixe as orientações em formato PDF para consulta offline.	PI-2

4.1.3 Requisitos não funcionais

Enquanto os funcionais dizem *o que* o sistema faz, os não funcionais descrevem *como* ele deve ser (qualidade, segurança e performance).

ID	Requisito Funcional	Não	Categoria	Descrição
RNF01	Segurança de Dados (LGPD)	de	Segurança	O sistema deve seguir o princípio de <i>Data Minimization</i> , não armazenando dados de busca de usuários não autenticados.
RNF02	Tempo de Resposta		Desempenho	As consultas às APIs externas devem ser processadas e exibidas em um tempo máximo de 5 segundos.
RNF03	Usabilidade (UX)		Usabilidade	A interface deve ser intuitiva para usuários leigos, evitando jargões técnicos excessivos sem a devida explicação.
RNF04	Disponibilidade		Confiabilidade	A aplicação deve estar disponível na web 24/7, utilizando serviços de hospedagem em nuvem estáveis.
RNF05	Compatibilidade		Portabilidade	A interface deve ser responsiva, funcionando adequadamente em navegadores desktop e dispositivos móveis.
RNF06	Criptografia		Segurança	Todas as comunicações entre o cliente e o servidor devem utilizar o protocolo HTTPS/TLS para evitar interceptação.

4.2 Histórias de usuário

4.2.1 Descrição das Histórias de Usuário

US01 – Consulta de Vulnerabilidade (PI-1)

- **História:** Como cidadão preocupado com minha segurança, eu quero inserir meu e-mail principal no sistema para verificar se minhas informações foram expostas em vazamentos de dados conhecidos.
- **CrITÉrios de Aceite:**
 1. O sistema deve validar se o formato do e-mail inserido é válido.
 2. O sistema deve retornar uma lista clara dos incidentes encontrados ou informar que nenhuma exposição foi detectada.

3. A consulta deve ser processada em tempo real (limite de 5 segundos).

US02 – Entendimento do Nível de Risco (PI-1)

- **História:** Como usuário leigo em tecnologia, eu quero visualizar um índice de risco (score) de fácil compreensão para que eu saiba a urgência de tomar medidas de proteção.
- **CrITÉrios de Aceite:**
 1. O score deve ser apresentado de forma visual (ex: termômetro ou cores de semáforo).
 2. O valor numérico deve ser derivado da ponderação de criticidade dos dados vazados (RN02).
 3. Deve haver uma breve legenda explicando o que o nível "Baixo", "Médio" ou "Alto" significa.

US03 – Tradução de Metadados via IA (PI-2)

- **História:** Como usuário sem conhecimento técnico, eu quero que a inteligência artificial explique em linguagem simples o que significa cada termo técnico do vazamento (ex: "SQL Injection" ou "Combolist") para que eu entenda o impacto real na minha privacidade.
- **CrITÉrios de Aceite:**
 1. A IA deve gerar um texto explicativo curto para cada incidente.
 2. O texto deve evitar jargões complexos, focando na consequência prática para o usuário.

US04 – Plano de Ação Preventivo (PI-2)

- **História:** Como vítima de uma exposição de dados, eu quero receber orientações passo a passo do que fazer para mitigar o dano, para que eu possa proteger minhas contas de forma assertiva.
- **CrITÉrios de Aceite:**
 1. As recomendações devem ser específicas para o tipo de dado vazado (ex: orientar troca de senha se "Passwords" foi exposto).
 2. O plano deve incluir links ou tutoriais simples sobre como ativar a autenticação em duas etapas (MFA).

US05 – Monitoramento de Histórico (PI-2)

- **História:** Como usuário cadastrado, eu quero salvar meu histórico de consultas para que eu possa acompanhar se as medidas que tomei reduziram meu score de vulnerabilidade ao longo do tempo.
- **CrITÉrios de Aceite:**

1. O sistema deve exigir login seguro para acessar o histórico.
2. O Dashboard deve exibir um gráfico comparativo entre a primeira consulta e a situação atual.

US06 – Autenticação e Privacidade (PI-2)

- **História:** Como usuário recorrente, eu quero criar uma conta protegida para que minhas consultas e dados de histórico não fiquem expostos a terceiros que utilizem o mesmo dispositivo.
- **CrITÉrios de Aceite:**
 1. O sistema deve permitir o cadastro com validação de e-mail.
 2. A senha deve seguir critérios de complexidade (mínimo 8 caracteres, números e símbolos).
 3. O acesso deve ser interrompido após um período de inatividade.

US07 – Gestão de Múltiplos Identificadores (PI-2)

- **História:** Como responsável pela segurança digital da minha família, eu quero cadastrar múltiplos e-mails no meu painel para monitorar a vulnerabilidade de todos os meus dependentes em um único lugar.
- **CrITÉrios de Aceite:**
 1. O usuário deve conseguir adicionar e remover e-mails da sua lista de monitoramento.
 2. O dashboard deve separar os resultados por identificador.

US08 – Notificações de Alerta Ativo (PI-2)

- **História:** Como usuário preventivo, eu quero ser notificado via e-mail assim que um novo vazamento contendo meus dados for detectado, para que eu possa agir antes que ocorra uma invasão real.
- **CrITÉrios de Aceite:**
 1. O sistema deve realizar varreduras automáticas periódicas.
 2. O alerta deve conter um link direto para o plano de ação sugerido pela IA.

US09 – Exportação de Plano de Mitigação (PI-2)

- **História:** Como usuário que deseja se organizar offline, eu quero exportar o plano de ação gerado pela IA em formato PDF para que eu possa segui-lo como um checklist de segurança.
- **CrITÉrios de Aceite:**
 1. O documento gerado deve conter o resumo do vazamento e as instruções passo a passo.

2. O arquivo deve ser leve e formatado para leitura em dispositivos móveis.

US10 – Administração e Auditoria (PI-2)

- **História:** Como administrador do sistema (Matheus/Lucas), eu quero visualizar métricas agregadas (anonimizadas) de consultas para entender quais são os vazamentos mais comuns e treinar melhor o modelo de IA.
- **CrITÉRIOS de Aceite:**
 1. O painel administrativo deve exibir o volume de consultas por período.
 2. Nenhum dado pessoal identificável dos usuários deve ser exibido nesta visão.

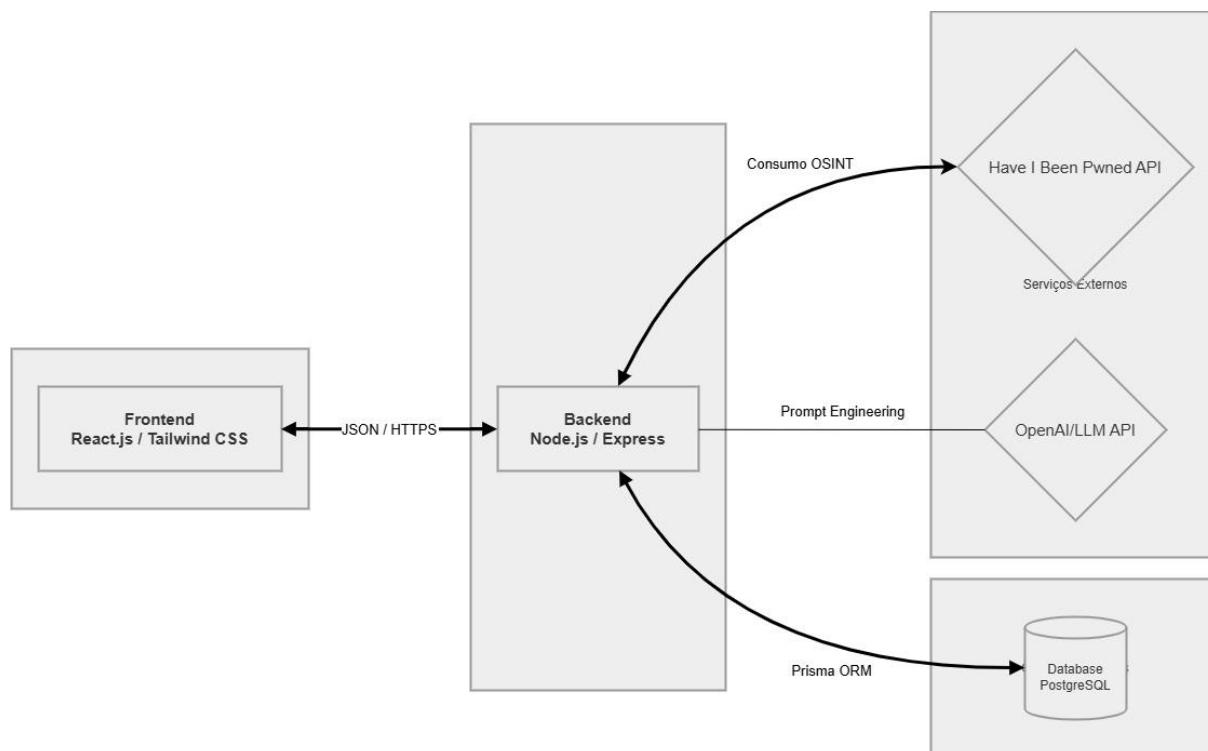
4.3 Arquitetura

4.3.1 Definições da arquitetura

A arquitetura do SafeID foi desenhada sob o paradigma de serviços desacoplados, garantindo escalabilidade e facilidade de manutenção. A estrutura divide-se em quatro camadas principais:

- **Frontend (React.js & Tailwind CSS):** Camada de apresentação focada em uma experiência de usuário (UX) fluida e responsiva para o público B2C. Utiliza o Tailwind CSS para garantir agilidade e consistência visual.
- **Backend (Node.js & Express):** Atua como o orquestrador do sistema. É nesta camada que reside o **Algoritmo de Risk Score** (o núcleo lógico do projeto), responsável por transformar metadados brutos de vazamentos em métricas compreensíveis para o cidadão.
- **Serviços Externos (APIs de Inteligência):** O sistema integra-se à API *Have I Been Pwned* para coleta de dados OSINT e à API da *OpenAI* para o processamento de linguagem natural. Esta **Camada de Inteligência** é o diferencial que traduz termos técnicos para uma linguagem acessível, cumprindo o pilar de Responsabilidade Social Digital do projeto.
- **Persistência (PostgreSQL & Prisma ORM):** A camada de dados utiliza o PostgreSQL gerenciado pelo Prisma ORM. O foco aqui é a segurança e conformidade com a LGPD, garantindo o armazenamento criptografado do histórico dos usuários para as entregas de PI-2.

4.3.2 Diagrama da arquitetura



4.4 Tecnologias

4.4.2 Front-end: React.js e Tailwind CSS

A interface do SafeID é concebida como o componente fundamental para a democratização da segurança digital, atuando na conversão de dados complexos em informações acionáveis pelo cidadão. Para viabilizar essa entrega, utiliza-se a biblioteca **React.js** (<https://react.dev/>), uma tecnologia líder de mercado fundamentada na arquitetura baseada em componentes. Esta escolha justifica-se academicamente pela eficiência do seu algoritmo de reconciliação (*Virtual DOM*), que permite atualizações granulares na interface sem a necessidade de recarregar a página integralmente, proporcionando uma experiência de uso fluida típica de aplicações de alta performance. Ao decompor a interface em unidades lógicas reutilizáveis, o React.js facilita a manutenção do código e a implementação de testes de usabilidade, garantindo que elementos críticos, como o *dashboard* de vulnerabilidades e o indicador de *Risk Score*, funcionem de forma isolada e resiliente.

Integrado à estrutura do React, o framework **Tailwind CSS** (<https://tailwindcss.com/>) é adotado para gerenciar a estilização da aplicação através do paradigma *utility-first*. Esta abordagem permite que o design do SafeID seja construído com foco na responsividade e na acessibilidade, garantindo que a ferramenta seja plenamente utilizável em diversos dispositivos, desde smartphones a desktops. A justificativa para o uso do Tailwind reside na otimização do ciclo de desenvolvimento e na redução significativa do tamanho dos artefatos finais de estilo, o que impacta diretamente no tempo de carregamento da aplicação — fator determinante para o

sucesso de produtos B2C. Além disso, a padronização visual oferecida pelo framework auxilia na conformidade com as diretrizes de design inclusivo, assegurando que as informações de risco sejam apresentadas com clareza e contraste adequados, respeitando os princípios de transparência previstos na LGPD.

Ao observar cases de sucesso como **Netflix** e **Airbnb**, que utilizam o ecossistema React para gerenciar interfaces dinâmicas em escala global, o SafeID alinha-se às melhores práticas de engenharia de software contemporânea. A sinergia entre estas tecnologias permite atingir um equilíbrio entre sofisticação técnica e simplicidade visual, transformando o *frontend* em um canal de comunicação eficaz para a Responsabilidade Social Digital. O resultado é uma aplicação capaz de processar retornos de APIs em tempo real e apresentá-los de forma didática, reduzindo a assimetria de informação entre especialistas em segurança e o público leigo, consolidando assim o valor social e técnico do artefato desenvolvido nesta disciplina.

Referências Bibliográficas

FEDERNEEL, A. **Full-Stack React, TypeScript, and Node: Build modern web applications using the Power of React, TypeScript, and Node.js**. 1. ed. [S.l.]: Packt Publishing, 2020.

META. **React: A JavaScript library for building user interfaces**. Disponível em: <https://react.dev/>. Acesso em: 05 mai. 2026.

MOORE, G. A. **Crossing the Chasm: Marketing and Selling Disruptive Products to Mainstream Customers**. 3. ed. New York: HarperBusiness, 2014.

TAILWIND LABS. **Tailwind CSS: Rapidly build modern websites without ever leaving your HTML**. Disponível em: <https://tailwindcss.com/>. Acesso em: 05 mai. 2026.

4.4.3 Back-end: Node.js, Express e Prisma ORM

A infraestrutura de serviços do SafeID, responsável por orquestrar a lógica de processamento e a comunicação entre o usuário e as bases de inteligência cibernética, foi desenvolvida sobre o ecossistema **Node.js** utilizando o framework **Express**. A escolha desta stack fundamenta-se no modelo de I/O não bloqueante e orientado a eventos do Node.js (<https://nodejs.org/>), que permite ao servidor lidar com múltiplas requisições simultâneas de consulta sem degradação de performance. Em um cenário B2C, onde a agilidade na resposta é um fator determinante para a retenção do usuário, essa arquitetura de processamento assíncrono justifica-se pela eficiência no consumo de recursos computacionais ao realizar chamadas externas às APIs OSINT e ao motor de IA.

Complementando o servidor de aplicação, o framework **Express** (<https://expressjs.com/>) é utilizado para prover uma camada mínima e flexível de roteamento, facilitando a criação de

uma API RESTful robusta. A modularidade do Express permite que o projeto integre com segurança os middlewares de validação de dados e autenticação, garantindo que as diretrizes de proteção previstas na LGPD sejam aplicadas antes mesmo que os dados cheguem à camada de persistência. A integração do **Prisma ORM** (<https://www.prisma.io/>) como ferramenta de mapeamento objeto-relacional (ORM) eleva o rigor técnico do projeto ao introduzir uma camada de abstração de dados tipada (*Type-safe*). O Prisma elimina erros comuns de sintaxe SQL e previne vulnerabilidades de segurança, como *SQL Injection*, ao mesmo tempo em que otimiza as consultas ao banco de dados PostgreSQL através de um motor de consulta eficiente e moderno.

Ao espelhar-se em arquiteturas de sucesso de empresas como **LinkedIn** e **Uber**, que utilizam o Node.js para gerenciar fluxos massivos de dados em tempo real, o SafeID assegura uma base tecnológica capaz de suportar o crescimento do volume de usuários monitorados. A sinergia entre o Node.js e o Prisma ORM permite que o projeto atinja um alto índice de manutenibilidade e confiabilidade técnica, transformando o backend em um núcleo resiliente de processamento de riscos. Esta construção assegura que o objetivo de democratizar o acesso à segurança digital seja cumprido através de um sistema estável, transparente e de alta disponibilidade, consolidando a viabilidade técnica do produto dentro do escopo acadêmico e social proposto.

Referências Bibliográficas

EXPRESS. **Express - Fast, unopinionated, minimalist web framework for Node.js.**

Disponível em: <https://expressjs.com/>. Acesso em: 05 mai. 2026.

NODE.JS. **Node.js® is a JavaScript runtime built on Chrome's V8 JavaScript engine.**

Disponível em: <https://nodejs.org/>. Acesso em: 05 mai. 2026.

PRISMA. **Prisma: Next-generation ORM for Node.js & TypeScript.** Disponível em:

<https://www.prisma.io/>. Acesso em: 05 mai. 2026.

TILKOV, S.; VINOSKI, S. **Node.js: Using JavaScript to Build High-Performance Network Programs.** IEEE Internet Computing, vol. 14, no. 6, p. 80-83, 2010.

4.4.4 Banco de Dados: PostgreSQL

A camada de persistência do SafeID é estruturada sobre o sistema de gerenciamento de banco de dados relacional **PostgreSQL** (<https://www.postgresql.org/>), escolhido por sua reputação histórica de confiabilidade, integridade de dados e suporte a recursos avançados de segurança. Academicamente, o PostgreSQL justifica-se por ser um banco de dados de código aberto que implementa rigorosamente os padrões SQL, oferecendo suporte nativo a tipos de dados complexos e extensões geoespaciais e de busca textual, o que pode ser explorado em evoluções

futuras do projeto. No contexto do monitoramento de vulnerabilidades, a integridade referencial e o suporte a transações ACID (Atomicidade, Consistência, Isolamento e Durabilidade) garantem que as informações de histórico de vazamentos e perfis de usuários sejam armazenadas sem riscos de corrupção ou perda de sincronia, pilares fundamentais para a confiabilidade de uma ferramenta de segurança digital.

A escolha tecnológica também se fundamenta na conformidade com a Lei Geral de Proteção de Dados (LGPD), uma vez que o PostgreSQL oferece mecanismos robustos de controle de acesso, auditoria e suporte à criptografia de dados em repouso. Em um projeto de Responsabilidade Social Digital, a proteção do dado do cidadão é o ativo mais precioso; portanto, a capacidade do PostgreSQL de lidar com volumes massivos de registros mantendo alta performance de consulta permite que o SafeID escale sua base de usuários sem comprometer a velocidade de resposta. A sinergia entre o banco de dados e o **Prisma ORM** (mencionado na camada de backend) assegura uma camada de persistência tipada, onde a estrutura das tabelas reflete diretamente a lógica de negócio do sistema, minimizando falhas de segurança e otimizando a indexação de dados para buscas rápidas por e-mails ou documentos comprometidos.

Espelhando-se em cases de sucesso de instituições financeiras e plataformas de tecnologia como **Instagram** e **Twitch**, que utilizam o PostgreSQL para gerenciar trilhões de registros com estabilidade crítica, o SafeID adota um padrão de excelência em armazenamento. O resultado dessa escolha é um ecossistema de dados resiliente, capaz de suportar as complexas correlações exigidas pelo Algoritmo de Risk Score. Através desta infraestrutura, o projeto atinge não apenas os requisitos técnicos de desenvolvimento de sistemas, mas também cumpre seu papel ético de prover um ambiente seguro para o armazenamento de informações sensíveis, consolidando a viabilidade do produto para o mercado B2C e para o ambiente acadêmico do IFSP.

Referências Bibliográficas

POSTGRES GLOBAL DEVELOPMENT GROUP. **PostgreSQL: The World's Most Advanced Open Source Relational Database**. Disponível em: <https://www.postgresql.org/>.

Acesso em: 05 mai. 2026.

MOMJIAN, B. **PostgreSQL: Introduction and Concepts**. 1. ed. [S.l.]: Addison-Wesley Professional, 2001.

SILBERSCHATZ, A.; KORTH, H. F.; SUDARSHAN, S. **Sistema de Banco de Dados**. 7. ed. Rio de Janeiro: Elsevier, 2020.

PRISMA. **Prisma: Next-generation ORM for Node.js & TypeScript**. Disponível em: <https://www.prisma.io/>. Acesso em: 05 mai. 2026.

4.4.5 Inteligência Artificial e APIs Externas

A capacidade analítica do SafeID e sua proposta de valor centrada na clareza de informações residem na integração estratégica de serviços de inteligência externa e processamento de linguagem natural. O sistema utiliza a API **Have I Been Pwned** (<https://haveibeenpwned.com/API/v3>), consolidada como o padrão global para verificação de comprometimento de dados através de fontes OSINT (*Open Source Intelligence*). A escolha desta API justifica-se pela sua abrangência e atualização constante, permitindo que o SafeID acesse um repositório histórico de bilhões de contas vazadas de forma ética e eficiente. Academicamente, essa integração exemplifica o uso de arquiteturas orientadas a serviços (SOA), onde o consumo de dados estruturados externos permite que a aplicação foque no tratamento e na apresentação de insights, em vez da manutenção onerosa de bases de dados de vazamentos próprias.

Complementando a coleta de dados, o SafeID incorpora a inteligência artificial através da API da **OpenAI** (<https://openai.com/api/>), especificamente utilizando modelos de linguagem de grande escala (LLMs). Esta camada de inteligência é fundamental para cumprir o objetivo social do projeto: a tradução do "técniqê" para uma linguagem acessível ao cidadão leigo. Através de técnicas de *Prompt Engineering*, o sistema processa os metadados técnicos dos vazamentos e gera recomendações personalizadas e planos de ação simplificados. Justifica-se o uso de modelos generativos pela sua capacidade superior de contextualização semântica, permitindo que o SafeID não apenas informe "que" houve um vazamento, mas explique de forma didática "o que isso significa" e "como se proteger", elevando o patamar da ferramenta de um simples buscador para um consultor de segurança digital.

A sinergia entre essas APIs externas e o **Algoritmo de Risk Score** desenvolvido internamente espelha-se em tendências de mercado observadas em empresas de cibersegurança como **CrowdStrike** e **Cloudflare**, que utilizam IA para mitigação de riscos e comunicação com o usuário. Ao adotar essas tecnologias, o SafeID atinge um diferencial competitivo e acadêmico, demonstrando como a integração de serviços globais de ponta pode ser aplicada para resolver problemas locais de vulnerabilidade digital. O resultado final é um sistema robusto, capaz de oferecer uma inteligência de dados comparável a soluções corporativas, mas com foco integral na alfabetização digital e na proteção do usuário B2C, consolidando a viabilidade técnica e o impacto social do projeto.

Referências Bibliográficas

BROWN, T. B. et al. **Language Models are Few-Shot Learners**. arXiv preprint arXiv:2005.14165, 2020. Disponível em: <https://arxiv.org/abs/2005.14165>.

HAVE I BEEN PWNED. **API Documentation - Version 3**. Disponível em: <https://haveibeenpwned.com/API/v3>. Acesso em: 05 mai. 2026.

OPENAI. **OpenAI API Documentation**. Disponível em: <https://platform.openai.com/docs/>. Acesso em: 05 mai. 2026.

STALLINGS, W. **Criptografia e Segurança de Redes: Princípios e Práticas**. 6. ed. São Paulo: Pearson Education, 2015.

4.4.4 Infraestrutura

4.4.4.1 Amazon Web Services (AWS) (exemplo, colocar todos, abrindo demais itens)

4.5 Testes e manutenibilidade

4.5.1 Plano de testes

4.5.2 Análise estática

4.5.3 Testes funcionais

4.5.3.1 Testes Unitários

4.5.3.2 Testes de Componente

4.5.3.3 Testes de Integração

4.5.3.4 Testes end-to-end

4.5.4 Testes não funcionais

4.5.4.1 Testes de performance

4.5.4.2 Testes de carga

4.5.4.3 Testes de configuração

4.5.5 Testes automatizados

4.5.6 Logs

4.5.7 Code convention

4.6 Segurança, privacidade e legislação

4.6.1 Critérios de segurança e privacidade

4.6.2 Observância à Legislação

4.7 Modelo de banco de dados

4.7.1 Modelo entidade relacionamento - MER / DER

4.7.2 Diagrama entidade relacionamento - DER (Tabelas)

4.7.3 Dicionário de dados

4.8 Duração / Cronograma (deve-se pensar a duração baseado no projeto não amarrado ao período do semestre)

4.8.1 Análise da duração do projeto (se não gerenciamento ágil, trazer o cronograma)

5 VIABILIDADE FINANCEIRA

5.1 Custos

5.2 Receitas

5.2 Cenário realista

5.3 Cenário otimista

5.4 Cenário pessimista

6 CONSIDERAÇÕES FINAIS

6.1 Dificuldades, escolhas e descartes

REFERÊNCIAS

APÊNDICES (materiais desenvolvidos pelo próprio autor do trabalho)

ANEXOS (matérias de outras fontes que não o próprio autor do trabalho)

REFERÊNCIAS BIBLIOGRÁFICAS

CHEN, Jing; HENRY, Elaine; JIANG, Xi. Is Cybersecurity Risk Factor Disclosure Informative? Evidence from Disclosures Following a Data Breach: J. Chen et al. **Journal of Business Ethics**, v. 187, n. 1, p. 199-224, 2023.

CHEN, Qiang; WANG, Lun. Social response and management of cybersecurity incidents. **Academic Journal of Sociology and Management**, v. 2, n. 4, p. 49-56, 2024.

CONTI, Mauro; DARGAHI, Tooska; DEHGHANTANHA, Ali. Cyber threat intelligence: challenges and opportunities. **Cyber Threat Intelligence**, [s. l.], p. 1-6, 2018.

FORTINET. **FortiGuard Labs report reveals 32.8 billion cyberattack attempts in Brazil in 2023**. 2024. Disponível em: <https://www.fortinet.com>. Acesso em: 18 abr. 2026.

IBM SECURITY. **Cost of a Data Breach Report 2023**. 2023. Disponível em: <https://www.ibm.com/security/data-breach>. Acesso em: 18 abr. 2026.

NEMEC ZLATOLAS, Lili; WELZER, Tatjana; LHOTSKA, Lenka. Data breaches in healthcare: security mechanisms for attack mitigation. **Cluster computing**, v. 27, n. 7, p. 8639-8654, 2024.

REUBEN-OWOH, Blessing; HAIG, Ella. A Systematic Review of Voluntary Cybersecurity Standards and Frameworks. **International Journal of Information Security**, v. 24, n. 5, p. 206, 2025.

SANTOS, J. F.; PINTO, G. Privacidade e segurança em sistemas de informação: uma análise dos aspectos psicológicos e cognitivos envolvidos na percepção e na adoção de medidas de segurança. **Revista Interface Tecnológica**, v. 21, n. 1, p. 288–299, 2025.

VON SOLMS, Rossouw; VAN NIEKERK, Johan. From information security to cyber security. **computers & security**, v. 38, p. 97-102, 2013.

ZHANG, Xichen et al. Data breach: analysis, countermeasures and challenges. **International Journal of Information and Computer Security**, v. 19, n. 3-4, p. 402-442, 2022.